

1

AI 기반 KCMVP 사전 적합성 검증 도구

2026.02.25 부채널 공모전 Project L3

로드맵 및 개요 작성

2394025 조수빈

AI 기반 KCMVP 사전 적합성 점검 도구

Target
Open Source Crypto Modules

! 배경 및 문제의식

- 📄 문서 vs 구현 불일치:
보안정책서와 실제 소스코드 간 괴리 발생
- 🚫 금지/권고 미준수:
위험한 난수 생성, 디버그 혹 등 필수 요건 누락
- 🔄 반복적 반례:
검증기관과의 커뮤니케이션 비용 과다 발생

🎯 연구 목표

사전 점검(Pre-check) 자동화

KCMVP 문서/가이드라인을 기반으로
오류 탐지 및 수정 제안(Patch) 을 자동 생성하여
반려 요인을 사전에 제거

🔍 핵심 과제 & 연구 질문(RQ)



하이브리드 탐지 (RQ1)

정규식/AST 를 기반 탐지 + LLM 문맥 해석
→ 부적합 요소를 유의미하게 탐지하는가?



수정 마크다운 생성 (RQ2)

근거, 위치, 권고 조치가 포함된 리포트 생성
→ 개발자가 "즉시 조치 가능"한 수준인가?



효율성 검증 (RQ3)

프로토타입 적용 및 정량/정성 평가
→ 질의/보완 루프 횟수를 줄일 잠재력 평가

📁 최종 산출물

- 📜 KCMVP Pre-check Rule (v1)
- 🔧 Prototype Tool (CLI)
- 📄 REPORT & Patch Suggestion

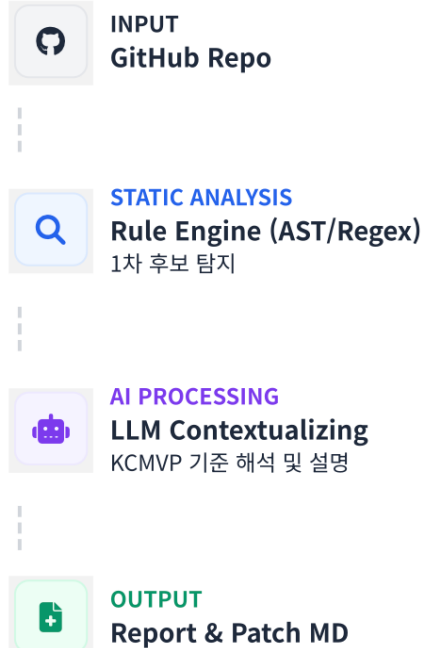
💡 기대 효과

단순 규정 검색이 아닌,
실무적 코드 수정안을 제시하여
개발자 편의성 극대화

방법론 및 4주 실행 계획

구현 파이프라인 설계 및 주차별 마일스톤

분석 파이프라인



검증 및 평가

Quantitative
룰 탐지 정확도
Precision / Recall 측정

Qualitative
조치 용이성
개발자 관점 3점 척도

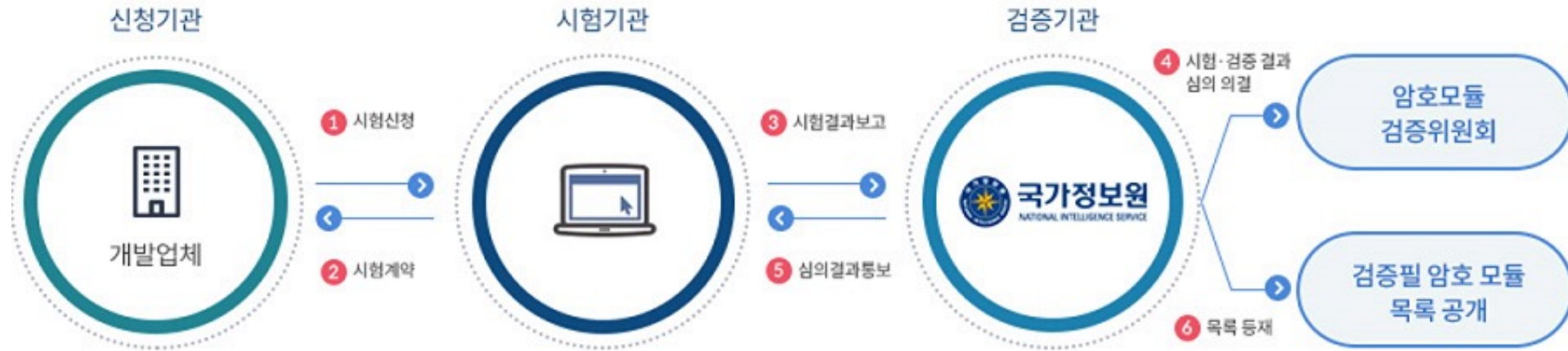
4주 실행 계획 (Weekly Plan)



1. KCMVP

- **한국형 암호모듈 검증제도(KCMVP)**
 - (KCMVP, Korea Cryptographic Module Validation Program)
 - 2009년부터 시행하고 있으며, 정보보호를 위해 국가·공공기관에서 비밀이 아닌 업무 자료를 보호하기 위해서는 KCMVP에서 인증받은 암호모듈의 사용을 요구하고 있음
- **검증필 암호모듈**
 - 암호 기술이 안전하게 구현되었는지 국가(국정원)가 확인하고 승인한 제품
 - KCMVP 인증 통과·표준 암호 알고리즘 사용이 통과되어야 함
 - 국가·공공기관 사업에서는 검증필 암호모듈 필수 탑재가 원칙

2. 기존 KCMVP 검증 절차의 문제



- 업체 내부에서 개발하고 문서를 준비하는 시간에 상당한 시간 소요
- 기관에서 검증 받는 기간이 평균 6개월 ~ 1년의 상당한 시간 소요
- 만약 보완 요구나 반려가 된다면 또다시 이를 수정하여 재시험 및 검증을 받아야 함
- 이를 다른 기업에 맡겨서 보완하려고 하면 매우 큰 비용이 소모됨
- 따라서 사전 점검을 통해 우리의 프로젝트 도구가 제출 전 단 1~2회의 보완 요구만 줄여주더라도, 출시 기간과 인건비를 매우 단축할 수 있음

3. 구현 목표

- AI 기반 KCMVP 사전 적합성 점검 도구
 - KCMVP 가이드라인을 학습한 AI → 소스코드를 분석 → 보안 결함 찾아서 보고서와 수정패치(.md) 제안
- 제출물
 - AI가 참조할 KCMVP 기반 룰셋
 - 프로토타입 툴 (아마 웹)
 - 툴을 통한 수정패치 예시 (실제 툴을 통한 출력물)
 - 최종 보고서 (성능 평가 포함) → 논문으로 고도화 진행해야 함
- 대상
 - 대칭키 암호 우선 진행 + LEA로 진행

4.1. 구체화: AI 룰셋 설계

- 여러 개 암호 한다고 가정

1) 공통 보안 룰셋

- 알고리즘이나 운영 모드에 상관 없이 KCMVP 인증을 위해 반드시 지켜야할 룰
- Ex) 잔존 정보 제거 여부, 에러 처리 여부

2) 알고리즘 공통 룰셋

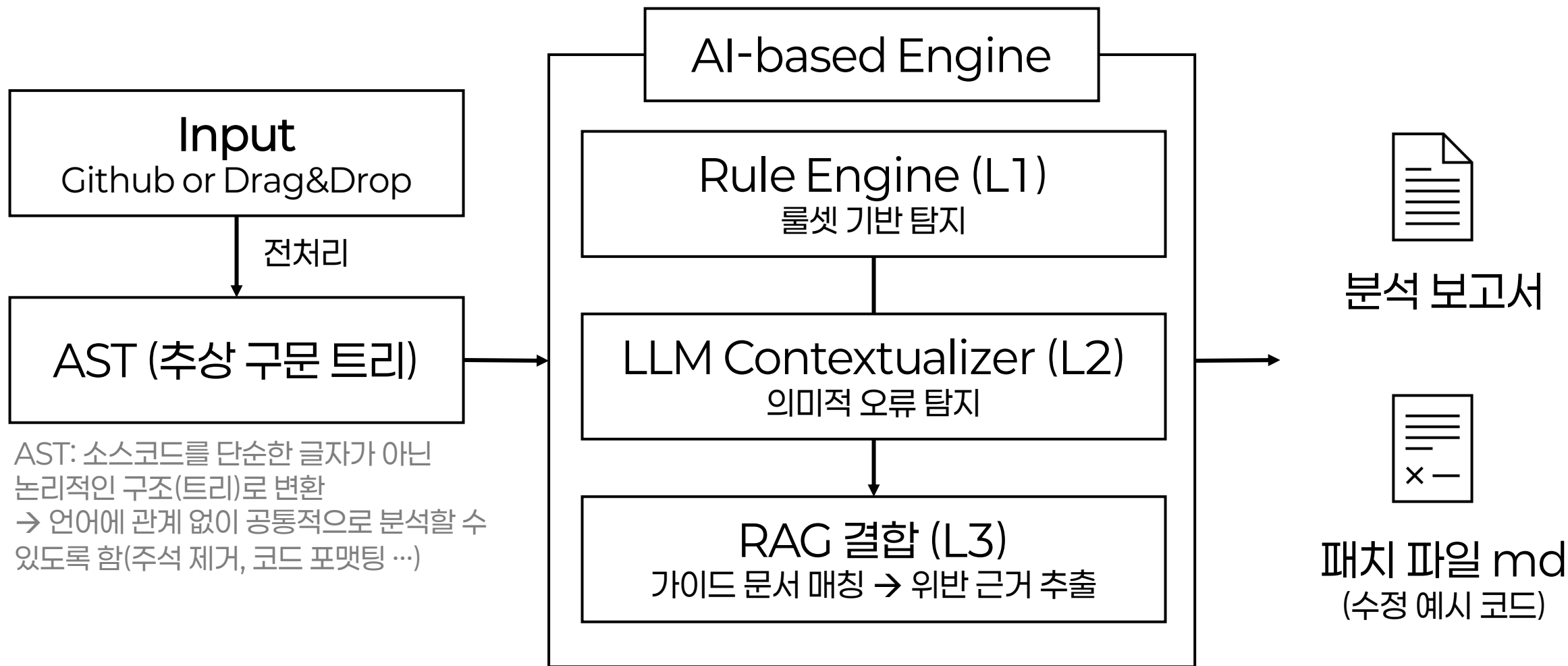
- 같은 알고리즘 내에서 알고리즘 자체의 구현이 잘 지켜졌는지 여부에 대한 룰
- Ex) 키 스케줄링 올바른가? 라운드 연산이 올바른가? 여부

3) 운영 모드 특화 룰셋

- 공통 알고리즘(ex.LEA) 내에서도 다양한 운영 모드가 존재하므로, 운영 모드에 따른 운영 모드 특화 룰
- Ex) CBC 모드에서는 IV의 랜덤성, CTR에서는 Nonce의 유일성...

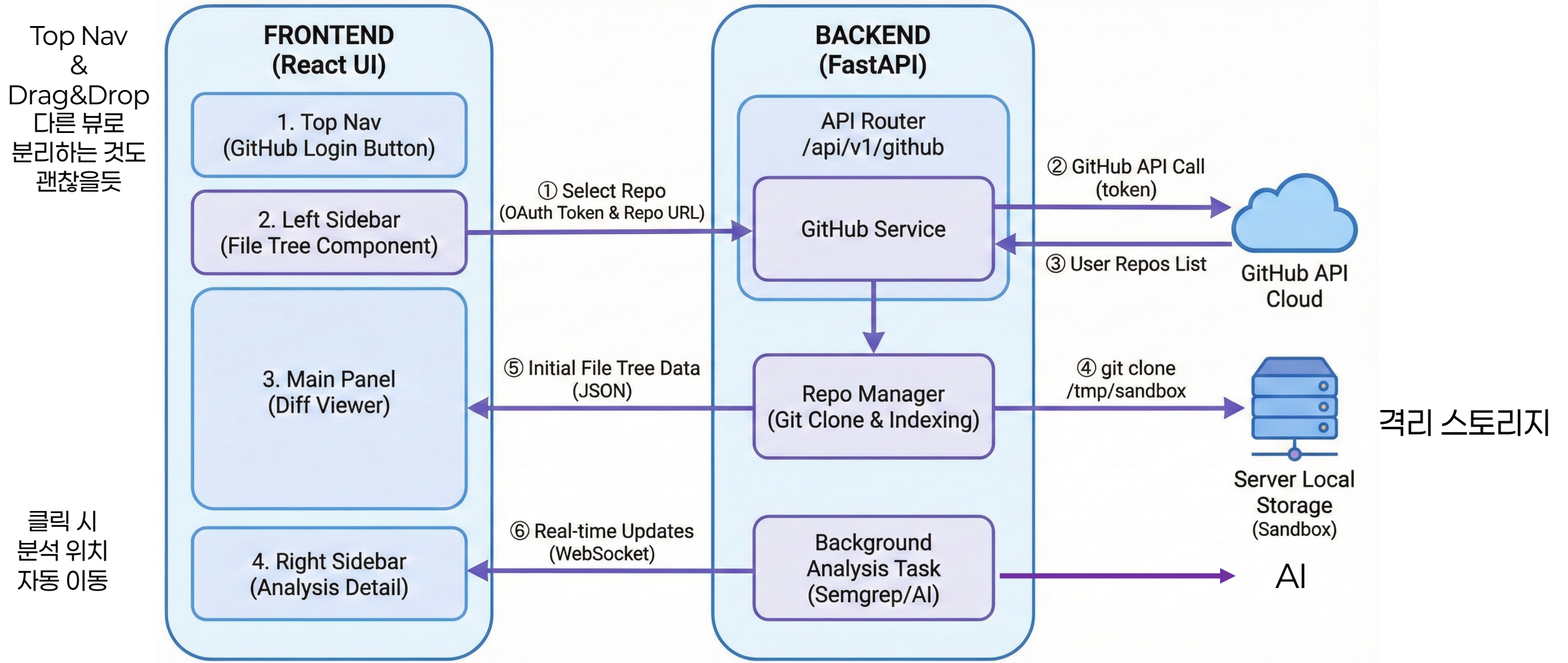
4.2. 구체화: 파이프라인

RAG: 검색 증강 생성 → 필요한 정보가 DB에 저장되어 있으면,
AI가 그 DB에서 원하는 문구를 찾아옴
→ 매번 모델 학습할 필요 없이 DB에 가이드라인 업데이트하면
된다는 이점 존재



4.3. 구체화: 프론트-백엔드 연동 구조

IDE 구성이랑 비슷하게 프론트 짜도 괜찮을 것 같음



5.1. 계획: 일정

일정

일단 이번주? 까지 교수님께 진행 사항 보고를 해야 해서

[1] ~2월 27일(금): 지금 기획안 바탕으로 진행해서 가능성 확인

[2] ~3월 초: LEA + ARIA 정도 완성 + 웹 연동

[3] ~ 3월 중순: 데이터셋 구상 및 실험 완료 + 오류 해결

[4] 3월 말 ~ 4월 초: 보고서 작성 → 논문으로

- 시간 되면: AES + a

- 시간 안되면: LEA만 일단

- 그리고 시간이 너무 촉박할 것 같아서 학부연구생도 아예 주제를 지금처럼 하나씩 맡아서 진행하고 서로 피드백 받는 형식으로 진행하는 게 나을 것 같습니다

5.2. 계획: 역할 분담

지금 문제가

(1) 대칭키 하나 룰셋 설정하고 돌려보는데 얼마나 걸리느냐

- 이거는 제가 아직 해보지 않아서 금요일까지 가능성을 봐야 알 것 같습니다.

[후보 1: (1) 이 쉬울 경우]

- 그러면 최대한 빨리 대칭키 하나 해보고 파이프라인 완료 → 한 명씩 대칭키 하나씩 맡아서 룰셋 세팅하고 실험 각자 돌려서 데이터 많이 쌓기
- 이 경우 역할 분담: 한 명당 대칭키 하나씩, 문서 작성 / 프론트 이렇게 나눔

[후보 2: (1) 이 어려울 경우]

- 그냥 대칭키 하나(LEA)로만 진행 → 난이도 확인 후 추후 역할 분담...

6. 참고 사이트 정리

- 1) 국가사이버안보센터-암호모듈검증:
<https://www.ncsc.go.kr/PageLink.do>
- 2) KISA 암호이용활성화-암호모듈검증:
<https://seed.kisa.or.kr/kisa/kcmvp/EgovSummary.do>
- 3) KISA 암호이용활성화-국산암호기술-LEA(논문 및 규격서 포함):
<https://seed.kisa.or.kr/kisa/algorithm/EgovLeaInfo.do>
- 4) 국가보안기술연구소. (2015). 블록암호 LEA 소스코드 사용 매뉴얼 (v1.0) : LEA 이걸로 보면 좋을듯 해요(교수님이 주신 자료에 있음)
- 5) 미래창조과학부, 한국인터넷진흥원. (2013). 암호기술 구현 안내서 (KISA 안내해설 제2011-9호)

2

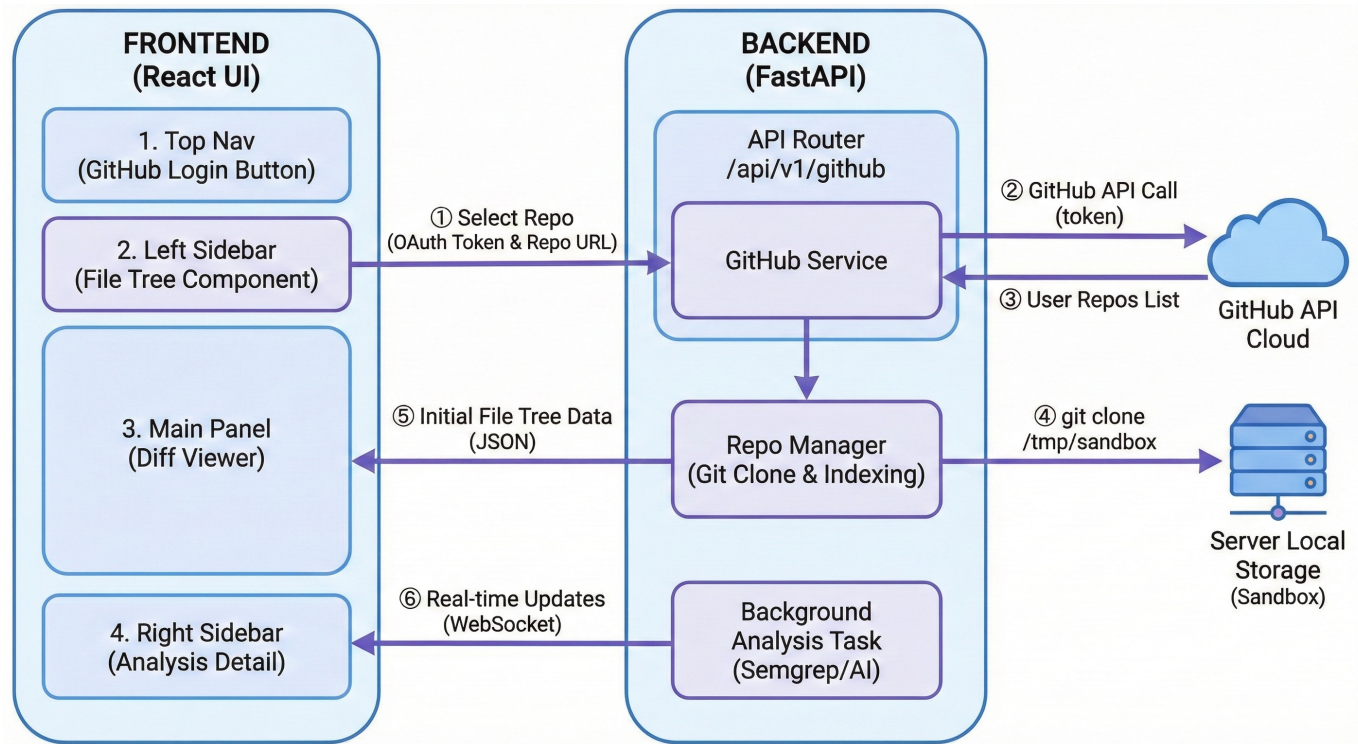
AI 기반 KCMVP 사전 적합성 검증 도구

2026.02.25 부채널 공모전 Project L3_2

진행 사항 공유

20260306 금요일 회의

진행 사항 요약: LEA로 진행하기로 함



- UI 설계는 대략적으로 완료

→ 추후 시간 남으면 AI 티 만나게 +
디테일한 부분 완성할 예정

- 깃허브 연동 x 일단은
zip으로 올리도록 설정

→ 테스트 완료 후 연동할 예정

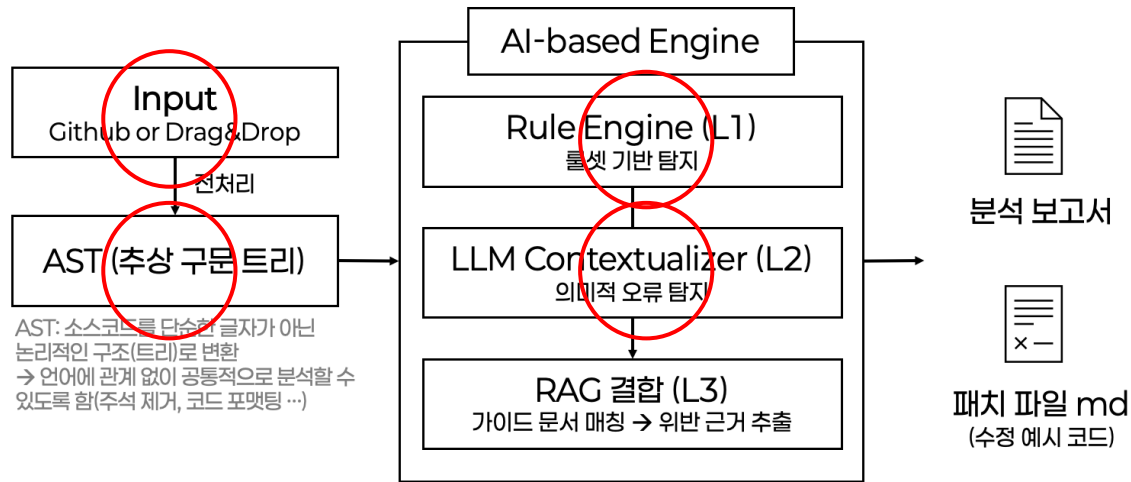
- 디테일 구현

→ 문서 - 코드 분리

→ 오류 위치 확인

→ IDE 유사 디자인

진행 사항 요약: LEA로 진행하기로 함



부채널 공모전: AI 기반 KCMVP 사전 점검

8

- 동그라미 친 부분: 백엔드 설계까지는 완료

→ L1은 구체화 진행 중

→ 깃허브 연동은 아직 진행 X

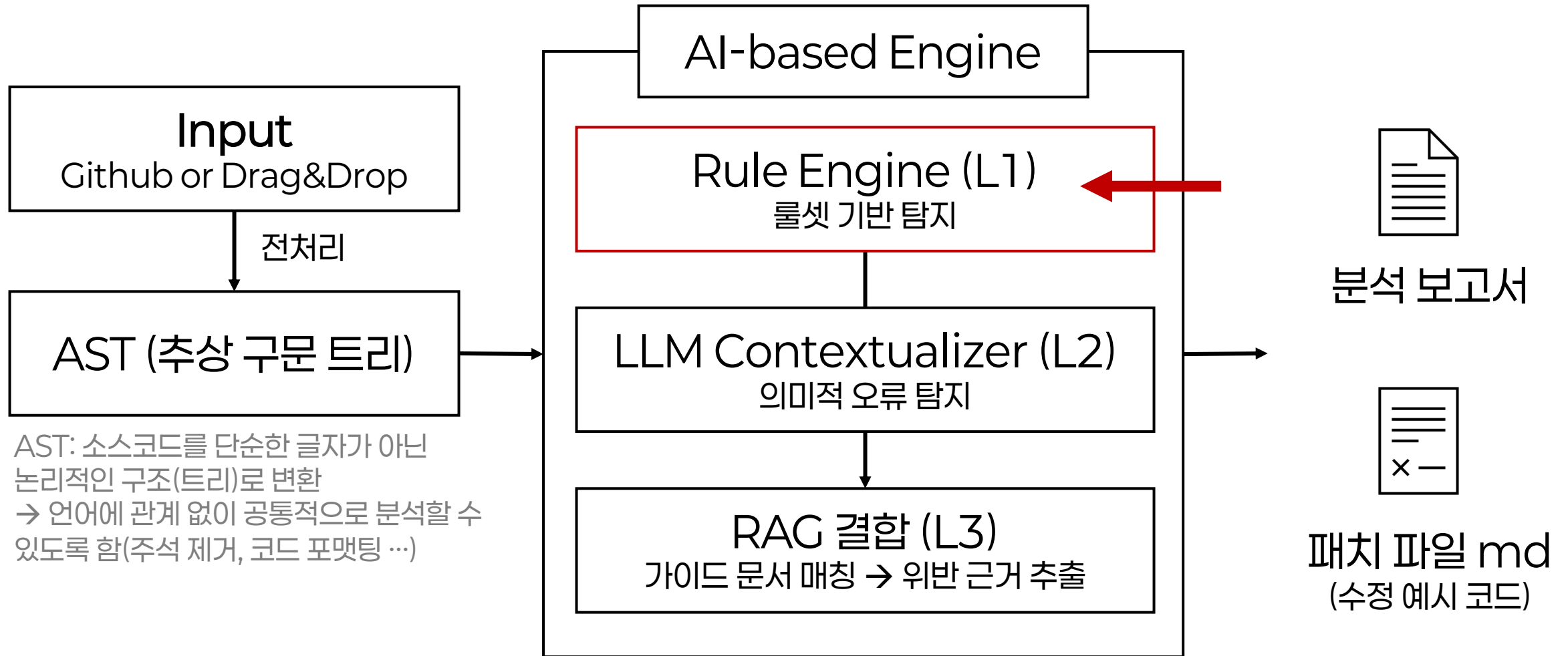
AI는 gemini-flash-lite-latest 사용(무료), 하루 20번 제한 존재

→ 그래서 서류 전체를 검토하는 건 어려울 것이라 판단 → L1에서 폭 넓게 체크

→ L2가 맥락을 보고 체크한 부분이 실제 문제인지, 맥락상 통과되는지 확인

→ L3에서 최종 확인하고 근거 인용

L1 구체화



L1 구체화 코드 부분 (초안)

1) 공통 보안 룰셋

- 알고리즘이나 운영 모드에 상관 없이 KCMVP 인증을 위해 반드시 지켜야할 룰
- Ex) 잔존 정보 제거 여부, 에러 처리 여부

2) 알고리즘 공통 룰셋

- 같은 알고리즘 내에서 알고리즘 자체의 구현이 잘 지켜졌는지 여부에 대한 룰
- Ex) 키 스케줄링 올바른가? 라운드 연산이 올바른가? 여부

3) 운영 모드 특화 룰셋

- 공통 알고리즘(ex.LEA) 내에서도 다양한 운영 모드가 존재하므로, 운영 모드에 따른 운영 모드 특화 룰
- Ex) CBC 모드에서는 IV의 랜덤성, CTR에서는 Nonce의 유일성...

L1 룰셋 구체화 1

backend/rules/

- common/
 - security.yaml # 코드: 알고리즘 공통 보안 룰
- algorithm/
 - lea.yaml # 코드: LEA 알고리즘 룰
 - aria.yaml # 코드: ARIA 알고리즘 룰 → 예시를 위한 것이고 사용 안할 것
- mode
 - cbc.yaml # 코드: CBC 모드 룰
 - ctr.yaml # 코드: CTR 모드 룰 + 추가 예정
- docs/
 - design.yaml # 문서: 기본/상세 설계서용 문서 룰(DOC-0xx)
 - config_mgmt.yaml # 문서: 형상관리 문서용 문서 룰(DOC-2xx)
 - test.yaml # 문서: 시험서(작성 안내서)용 문서 룰(DOC-1xx)
- traceability/
 - traceability.yaml # 설계-코드-시험 추적성 룰(TRC-xxx)

사용할 문서 정리

문제: 암호모듈 요구 사항이 유료

KSSN(한국표준정보망) KS X ISO /IEC 19790 – 암호모듈 보안 요구사항:

➔ 암호 모듈을 위한 보안 요구사항 안내

• KSSN(한국표준정보망) KS X ISO/IEC 24759 – 암호모듈 시험 요구사항:

➔ 명세된 요구사항에 대해 시험하기 위해 시험기관이 사용하는 시험방법을 명세

아래 문서들로 대체 예정

• KISA 암호이용 활성화: 암호모듈 제출물 작성 안내서(2025. 9.):

<https://seed.kisa.or.kr/kisa/Board/203/detailView.do>

• ➔ 암호모듈 제출물 작성을 위한 구현 안내서

• LEA 소스코드 사용 매뉴얼(v 1.0, 국보연) / 128비트 블록암호 LEA 규격서

화면

KCMVP Pre-Validator

암호 모듈 정적 분석 도구

GitHub 링크나 ZIP 파일을 업로드하면 KCMVP 룰로 소스를 분석하고, 위반 위치와 설명을 IDE 형태로 보여줍니다.

ZIP 파일(.zip)만 업로드할 수 있습니다.

GitHub 레포 분석

공개 레포지토리 URL을 붙여넣고 분석을 시작합니다. (현재는 ZIP 우선 지원)

GitHub 링크로 분석

아래 한 줄에서 코드 ZIP과 3종 문서 PDF(설계서 / 형상관리 / 시험서)를 함께 업로드하세요.

ZIP(코드) 1개 + PDF(문서) 3개까지 업로드할 수 있습니다. 문서는 텍스트 기반 PDF를 권장합니다.

ZIP 파일로 분석

화면

KCMVP 사전 점검

새 분석

GitHub URL 또는 owner/repo

파일 선택

선택된 파일 없음

알고리즘

모드

ZIP: ast_test.zip

파일 7개

위반 4건 (H 4 · M 0 · L 0)

분석 완료

설계서

형상관리 문서

시험서

코드

종합

파일 트리

src/hardcoded_key.c

src/uses_secure_clear.c

src/has_explicit_bzero.c

src/no_clear.c

src/secure_clear.c

src/has_memset.c

include/secure_clear.h

선택된 파일: src/hardcoded_key.c

전체 파일 AST 보기

파일 전체 흐름 보기

이 파일에는 파일 전체 수준의 위반 (COM-001 등)이 있습니다. 잔존 정보 제거 코드가 전혀 없거나, 가이드라인에서 요구하는 처리 로직이 누락되어 있을 수 있습니다.

```
1
2 static const unsigned char KEY[16] = {
3     0x01, 0x23, 0x45, 0x67, 0x89, 0xAB, 0xCD, 0xEF,
4     0xFE, 0xDC, 0xBA, 0x98, 0x76, 0x54, 0x32, 0x10
5 };
6 void use_hardcoded(void) {
7     encrypt_block(KEY);
8 }
9
```

요약

위반 목록

패치

분석 완료

COM-001

src/hardcoded_key.c:전체

잔존 정보 제거

COM-001

src/no_clear.c:전체

잔존 정보 제거

COM-001

include/secure_clear.h:전체

잔존 정보 제거

COM-003

src/hardcoded_key.c:3

하드코딩된 키/IV 금지

진행 목표 및 역할 분담

- ~3월 16일 (학부생 회의):
 - 룰셋 설계 어느정도 완료
 - RAG 파이프라인 연결 및 AI 최적화 완료
 - 출력될 최종 보고서 형태 형식 구성 완료
- 현재 역할 분담
 - 룰셋 설계를 LEA 알고리즘 파트 / 서류 관련 파트로 나눠서 진행

Q

- AI 부분: 로컬에서 해도 괜찮
- 서류부분: 소프트웨어 기본적 (security 1 이면서 소프트웨어인 것만 (펌웨어 x)) → 이 부분도 크롭해서 넣도록 하라
- 진행도 : 4페이지 이내(양식)
- 논문: phase그림 다이어그램 ★ + 화면 포함 (선택), 참고문헌
할루시네이션을 조심하라!!! (이중 검증을 하라...)